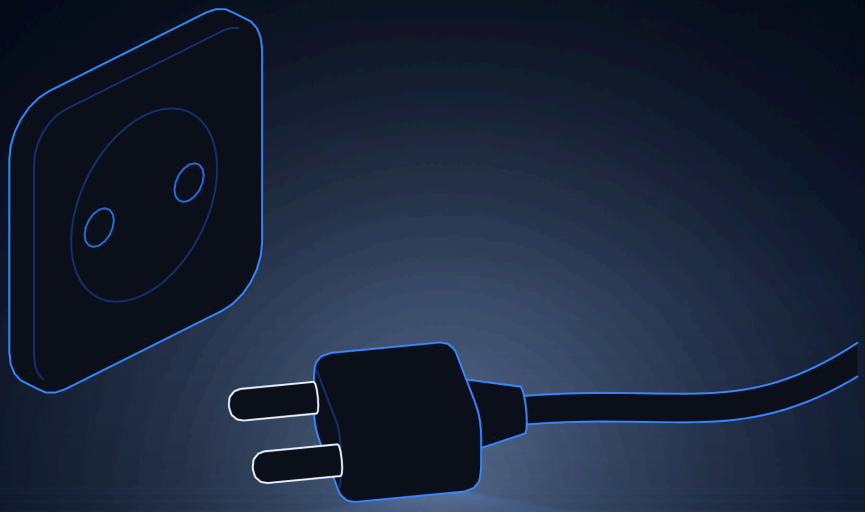


HOT TOPICS · CLOUD RESILIENCE

When the cloud goes dark.

One power fault in one London data centre zone disrupted banks, parcel firms and court hearings. A practical playbook for mapping your cloud dependencies and staying up when a provider does not.

INSIDE

Contents

A practical guide to cloud concentration risk for UK organisations: what happened in London on 20 October, how to map what you depend on, how to design and test for failure, and what to do this week, this month and this quarter.

Foreword 03

Introduction 04

01 What happened 06

02 Map and design 09

03 Rehearse and recover 14

Sources 24

FOREWORD

Your systems may be resilient. Is everything they depend on?

On the morning of Tuesday 20 October 2026, a power disruption at the data centre hosting one of the three zones in Google Cloud's London region set off a chain of failures. For about six hours, customers in the UK and beyond found that card payments, banking apps, parcel tracking and court video links were slow, broken or simply gone.

Most of the organisations affected did not choose to be exposed to one building in one part of London. Many will have spread their own systems across zones as the provider recommends. Others will have been exposed through suppliers whose own services ran in the affected region. And Google says that even parts of the region that kept power were affected.

This playbook is for UK business and IT leaders who want to understand that risk and reduce it at a sensible cost. It is not an argument against cloud, or against any one provider. Every provider has outages. The question is whether you know what happens to your business when yours does, and whether you have tested the answer.



The Transputec team
Transputec

INTRODUCTION

Three habits for when the cloud goes dark.

Concentration risk is not solved by moving everything to a second provider. It is managed by knowing what you depend on, designing each service to the level of failure it must survive, and rehearsing the recovery.



Know what you depend on

Map every critical service down to the region and zone it runs in, including the clouds your suppliers use.



Design to the right level

Decide for each service whether it must survive a zone, a region or a provider failing, and pay only for that.



Rehearse the bad day

Write runbooks, practise failover, and plan how you will tell customers and staff what is going on.

One zone failed. Three zones felt it.

Google says the power loss was confined to one London zone, yet some workloads in the other two were also hit. Resilience plans have to allow for failures that do not stay in their box.

01

PART 01

What happened.

A power fault, a generator that did not start, and a region that wobbled for six hours.

01 The London outage in brief

02 Hour by hour

03 Why regulators are paying attention

WHAT HAPPENED

How one power fault reached banks, couriers and courts

> **Spreading across zones helped many workloads, but it was not a guarantee.**

Google's incident report says a disruption to the utility supply hit the data centre facility hosting zone europe-west2-b, one of three zones in its London region. The site switched to battery power as designed, but its emergency generators never took the load. Both the primary and backup control systems failed to start them, and when the batteries ran down, servers, storage and network kit in that zone lost power.[1] Google described the site as a third-party facility.[2]

The outage ran from about 07:00 to just after 13:00 UK time, which Google's final report puts at six hours and eight minutes. A small number of customers saw problems for longer.[1,3] Google listed more than 30 affected products, from virtual machines to databases and storage.[1,4]

Revolut customers reported problems with card payments, transfers, cash withdrawals and signing in, and the firm said customers' money and data were safe. Lloyds and HSBC confirmed customers had problems, and users reported issues with Royal Mail, DPD and Rightmove.[2,5] HM Courts and Tribunals Service's cloud video platform, used for hearings in England and Wales, also went down.[5,6]

The most important detail for architects is what happened next door. Google says some customers running in the two unaffected zones were also hit, because of sudden demand on the remaining capacity and control-plane checks that depended on the offline zone and timed out.[1] Spreading across zones helped many workloads, but it was not a guarantee.

Google's final report, published on 27 October, traces the generator failure to wiring and logic errors in the control system, and lists fixes including checks at similar sites worldwide by 15 November.[1] It also notes that customers must provision their own failover where they need it.

Regulators were already watching. In July, HM Treasury designated Google Cloud EMEA and three other cloud providers as critical third parties to the UK financial sector, bringing their services to finance under Bank of England, PRA and FCA oversight.[7] On the day of the outage the chair of the Treasury Committee wrote to the Bank and the FCA asking how they would use those powers.[8] The regime does not shift responsibility: firms remain accountable for their own resilience.[9]

HOUR BY HOUR

Tuesday 20 October, in UK time

Times are taken from Google's incident report and contemporary reporting. Early reports differed by a few minutes.

WHEN	WHAT HAPPENED
About 07:00	Power disruption at the facility hosting europe-west2-b. Generators fail to start; batteries run down.[1]
07:00 to 08:00	Reports spike for Revolut, Lloyds, HSBC and others. Court video links start to fail.[5,6]
Morning	Google confirms a power event, offers no workaround and suggests moving workloads to another zone or region.[3,5]
About 13:00	Google reports recovery for most workloads. Its final report closes the incident at 13:08.[1,4]
Afternoon	A very small number of customers still affected. The FCA says it is engaging with Google and affected firms.[4,8]
22 and 27 Oct	Preliminary and final incident reports explain the generator control fault and the spillover to other zones.[1]

02

PART 02

Map and design.

Find out what you really depend on, then choose how much failure each service must survive.

01 Mapping dependencies, including your suppliers' clouds

02 Zone, region or provider

03 Setting recovery objectives

THIS MONTH

Map your cloud dependencies in five steps

Start with the services customers and staff would notice first. A spreadsheet is enough.

01 List your critical business services

Payments, ordering, customer portals, phones, payroll, case management. Name a business owner for each, not just a system.

02 Trace each one to where it runs

For every component, record provider, region and zone, plus shared parts such as identity, DNS, monitoring and secrets.

03 Ask suppliers the same question

Your payment processor, CRM, phone system and managed service provider all run somewhere. Ask which provider, region and zones, in writing.

04 Find the single points

Look for anything in one zone, one region or one supplier, and for many suppliers quietly sharing the same cloud region.

05 Agree a tolerance and an owner

For each service, write down how long the business can live without it and who decides when to fail over.

REMEMBER

A supplier's outage is your outage. Your map is incomplete until it includes the clouds your suppliers use.

THE TRADE-OFFS

Multi-zone, multi-region or multi-cloud?

Each step up protects against a bigger failure and costs more to build, run and test.

OPTION	PROTECTS AGAINST	COSTS AND CATCHES
Single zone	Very little. Server or disk failure, if you have spares.	Cheapest. A zone outage like London's takes you down completely.
Multi-zone	Loss of one zone, which is the provider's recommended baseline.[10]	Modest extra cost. October showed neighbouring zones can still be strained.
Multi-region	Loss of a whole region, such as London.	Data replication, extra capacity, latency and data residency choices to settle.
Multi-cloud	Loss of a provider, or a provider-wide control problem.	Highest cost and skills burden. Often slower to recover if untested.
Offline fallback	Everything digital failing at once.	Paper forms, a second bank card, manual processes. Cheap, but needs practice.

TIERING

Match the design to the damage

Plot each service by how much harm an outage causes and how fast the harm grows. Invest top right first.

↑ BUSINESS IMPACT

TIER 2: MULTI-ZONE

High impact, slow harm

Payroll, reporting, internal tools. Multi-zone, with a tested restore into another region within a day or two.

TIER 1: MULTI-REGION

High impact, fast harm

Payments, customer logins, ordering. Run warm in a second region, with failover rehearsed at least twice a year.

TIER 3: RESTORE

Low impact, slow harm

Archives, test systems. Good backups held in another region. Rebuild when convenient.

TIER 2: DEGRADE

Low impact, fast harm

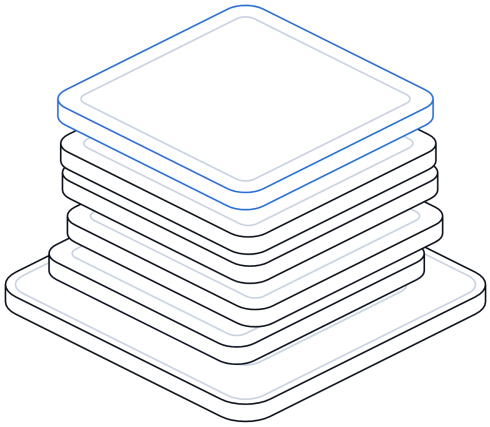
Website features, notifications. Multi-zone, plus a simple holding page or reduced service mode.

SPEED OF HARM →

RECOVERY OBJECTIVES

Four numbers to agree for every critical service

Agree them with the business owner and test against them. Without them, nobody knows when to fail over.



01 **Maximum tolerable outage**

How long before harm to customers or revenue becomes unacceptable. Finance calls this impact tolerance.

02 **Recovery time objective**

How quickly the service must be back, comfortably inside the maximum outage.

03 **Recovery point objective**

How much recent data you can lose, which sets how often you replicate.

04 **Decision time**

How long you wait for the provider before failing over. Decide in advance.

03

PART 03

Rehearse and recover.

A failover plan that has never been run is a hope, not a plan.

01 Runbooks and testing

02 Status communication

03 Contracts, exit and your 90-day plan

RUNBOOK

The first two hours of a regional outage

Keep a copy of this runbook outside the cloud it protects, and name a deputy for every step.

Detect independently

Use external monitoring that does not run in the same region, so you hear about it before customers do.

Confirm scope

Check the provider's status page and your own telemetry. Which zones, which services, which suppliers?

Decide by the clock

When the pre-agreed decision time passes, the named owner decides whether to fail over. No committee.

Fail over or degrade

Shift traffic to the standby region, or switch to reduced service and manual workarounds.

Recover and review

Fail back carefully, reconcile data, and write up what worked within two weeks.

> Google's advice on the day was to move workloads to another zone or region. That only works if the capacity, data and permissions are already there.

TESTING FAILOVER

Six rules for tests that mean something

Most failover plans fail on details: an expired credential, a missing quota, a DNS record nobody can change.

01 **Test the scenario that happened**

Simulate losing a whole zone and a whole region, including shared services such as identity and DNS.

02 **Start small and planned**

Begin with a scheduled tabletop, then a failover of one low-risk service, then a full exercise.

03 **Measure against your objectives**

Record actual recovery time and data loss, and compare them with the numbers you agreed.

04 **Check capacity and quotas**

Confirm the standby region can actually take the load. In October, demand surged on surviving capacity.[1]

05 **Include your suppliers**

Ask key suppliers to show their own failover results, or to join your exercise.

06 **Fix, then retest**

Every test produces actions. Give each an owner and a date, and repeat the test.

STATUS COMMUNICATION

Tell people what is happening, early and often

During the outage, many people reported problems on trackers such as Downdetector.[5] Be the source they trust.

Have a status page off your main cloud

Host it with a different provider, so it stays up when your services do not, and keep templates ready.

Name who speaks

One person approves updates to customers, staff, regulators and the press, with a deputy.

Update on a rhythm

Every 30 to 60 minutes, even with no news. Say what is affected, what is safe and when you will next update.

Know who you must tell

Regulated firms may have notification duties. Check contracts and rules now, not mid-incident.

> Revolut's first message stressed that customers' money and data were safe. Say what is not affected as clearly as what is.[5]

IN PRACTICE

Three organisations, three levels of resilience

PAYMENTS START-UP

Customer app runs in one region

THE GAP

Multi-zone in London, but no second region and identity tied to the same region.

THE FIX

Warm standby in a second region for login and payments, with replicated data and pre-approved quotas.

THE CHECK

Twice-yearly failover exercise, timed against a two-hour recovery objective.

WATCH OUT

Data residency and latency between regions. Agree them with compliance early.

REGIONAL DISTRIBUTOR

Relies on a SaaS warehouse system

THE GAP

Own systems were fine, but the warehouse supplier ran in a single cloud region.

THE FIX

Supplier asked for its region, zones and recovery objectives, and a paper picking process agreed.

THE CHECK

Manual dispatch drill run with one depot each quarter.

WATCH OUT

Supplier answers can be vague. Ask for evidence of tests, not policies.

LAW FIRM, 300 STAFF

Hearings and client calls by video

THE GAP

No fallback when court or client video platforms failed.

THE FIX

Telephone dial-in details for every hearing and a second conferencing tool approved.

THE CHECK

Fee earners know the fallback and where to find dial-in numbers.

WATCH OUT

Court platforms are outside your control. Contact the court early.

CONTRACTS AND EXIT

Questions to settle before you sign or renew

Most cloud and SaaS contracts favour the provider. You may not change the terms, but you should know them.

TOPIC	WHAT TO ASK	GOOD LOOKS LIKE
Location	Which provider, regions and zones host our data and service?	Named in writing, with notice before any change.
Resilience	What is your recovery objective for a zone or region loss?	Stated objectives, with recent test evidence.
Incidents	How fast will you tell us, and through what channel?	Alerts within an agreed time, not only a public status page.
Service credits	What do credits cover and what are they worth?	Understood. Credits rarely cover your real losses.
Exit	How do we get our data out, in what format, and how fast?	A documented, tested export route and a realistic notice period.
Subcontractors	Who else do you rely on to deliver this service?	A list of key subcontractors and their locations.

YOUR PLAN

This week, this month, this quarter

Owners are suggestions. Adjust them to your structure.

WHEN	ACTIONS	OWNER
This week	List your top ten business services and the region and zones each runs in. Check whether any were hit on 20 October.	Head of IT
This week	Ask your five most important suppliers which cloud regions they use and how they fared on 20 October.	Procurement lead
This month	Agree recovery objectives and a tier for each critical service. Set up monitoring and a status page off your main cloud.	Service owners
This month	Write the regional outage runbook, name decision owners and run a tabletop exercise.	IT operations lead
This quarter	Build standby for tier 1 services, run a live failover test and fix what it finds.	Head of IT
This quarter	Review contracts and exit plans. Report residual concentration risk to the board.	IT director

FOR LEADERS

Questions for your board and your suppliers

Ask them out loud. Vague answers are the finding.

FOR THE BOARD

- ? Which of our services would stop if one cloud region went dark for six hours, and what would it cost?
- ? When did we last test failing over, and did we meet our recovery objectives?
- ? Who has authority to trigger failover, and how fast can they decide?

FOR SUPPLIERS

- ? Which provider, region and zones run our service, and what happens if one fails?
- ? Were you affected on 20 October, and what have you changed since?
- ? How will you tell us about an outage, and how do we get our data out if we leave?

CHECKLIST

Are you ready for the cloud to go dark?

Tick what is true today. Anything blank is your next action.

- [ ] **Services mapped to provider, region and zone**
  Including identity and DNS.
- [ ] **Suppliers' cloud locations confirmed in writing**
- [ ] **Recovery objectives agreed per service**
  With an owner and a decision time.
- [ ] **Design matches the tier**
  Tier 1 services survive the loss of a region.
- [ ] **Runbook stored outside the cloud it protects**
  With named owners and deputies.
- [ ] **Failover tested in the last six months**
  With results recorded and actions closed.
- [ ] **Status page and templates ready, hosted off your main cloud**
- [ ] **Exit route documented and tested**
  For each critical service.

GLOSSARY

Words worth knowing

Region

A geographic area where a cloud provider runs data centres, such as London (europe-west2).

Zone

A separate part of a region with its own power and networking, designed to fail independently.

Concentration risk

The danger of many services, or many firms, depending on the same provider or location.

Control plane

The provider systems that create, manage and check resources, as opposed to running them.

Failover

Moving a service to standby resources when the primary ones fail.

Recovery time objective

The target time to restore a service after it fails.

Recovery point objective

The maximum amount of recent data you can afford to lose.

Impact tolerance

The UK financial regulators' term for the maximum tolerable disruption to an important business service.

Critical third party

A provider designated by HM Treasury whose services to UK finance are overseen by the regulators.

UPS

Uninterruptible power supply: batteries that bridge the gap until generators start.

SOURCES

Sources and notes

Sources were accessed on 4 November 2026. Times are UK time (BST). Google did not name the facility operator. Source 9 explains that firms remain accountable for their own resilience when a provider is designated.

1 Google Cloud Service Health, incident Xs2XTHzAVC9YnafnPyzj, preliminary (22 Oct) and final (27 Oct 2026) reports. status.cloud.google.com/incidents/Xs2XTHzAVC9YnafnPyzj

2 AFP via eNCA, Power outage hits Google Cloud services, disrupting UK banks, 20 Oct 2026. enca.com/business/power-outage-hits-google-cloud-services-disrupting-uk-banks

3 The Register, Google Cloud's London zones takes a nap, multiple services disrupted, 20 Oct 2026. theregister.com/paas-and-iaas/2026/10/20/ (article 5304084)

4 The Register, Google Cloud says a 'power event' caused today's outage, 20 Oct 2026. theregister.com/paas-and-iaas/2026/10/20/ (article 5304160)

5 PA Media via Yahoo News UK, Banks and courts affected by disruption as Google apologises for cloud outage, 20 Oct 2026. uk.news.yahoo.com/banks-courts-affected-disruption-google-114059868.html

6 The Irish Times, Millions affected by Revolut disruption linked to Google Cloud outage, 20 Oct 2026. irishtimes.com/business/2026/10/20/revolut-services-hit-by-outage-including-in-ireland/

7 HM Treasury, UK financial system strengthened with new safeguards for major technology providers, 10 Jul 2026. gov.uk/government/news/uk-financial-system-strengthened-with-new-safeguards-for-major-technology-providers

8 City AM, UK watchdogs push for answers on Google Cloud outage, 20 Oct 2026. cityam.com/revolut-hit-with-service-disruption-as-users-unable-to-make-payments/

9 Bank of England, PRA and FCA, PS16/24 Operational resilience: critical third parties to the UK financial sector, 12 Nov 2024. bankofengland.co.uk

10 Google Cloud documentation, Regions and zones, accessed Nov 2026. docs.cloud.google.com/compute/docs/regions-zones

TRANSPUTEC

Want to know what breaks when a zone goes dark?

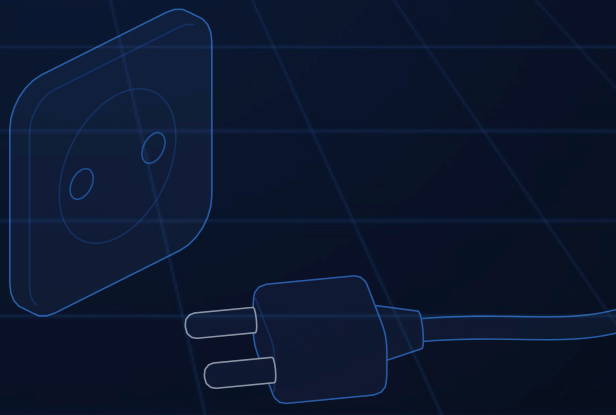
Transputec helps UK organisations map their cloud and supplier dependencies, design for the failures that matter, and rehearse recovery before they need it.

Book a cloud resilience review

transputec.com

NEXT IN THE SERIES

No. 09 · Ransomware gets an upgrade





HOT TOPICS · RANSOMWARE AND AI

Ransomware gets an upgrade.

The NCSC says AI is highly likely to feature in a ransomware attack on UK critical infrastructure by 2028. A UK school estate may already have seen an early version. Here is what to do now.

INSIDE

Contents

A practical guide for UK organisations as ransomware becomes faster and more automated: what the NCSC and Bitdefender reported this week, the basics that still stop most attacks, and how to be ready for the bad day.

Foreword 03

Introduction 04

01 What happened 06

02 Shut the easy doors 10

03 Ready for the bad day 16

Sources 24

FOREWORD

The tools are changing. The ways in are not.

On 3 November 2026 the NCSC published its Annual Review, subtitled The State of the Cyber Nation. One judgement stood out: it is highly likely that, between now and 2028, AI-powered malware will have been used in a ransomware attack on UK critical national infrastructure.[1]

The same day, Bitdefender described a ransomware attack on a UK school estate in which the commands looked as if they had been written by a language model, possibly running in a loop that fed results back to it. Bitdefender is careful to call that a working model rather than a proven fact.[2]

It would be easy to read both as a story about clever machines. The more useful reading is plainer. The NCSC says most successful attacks still start with familiar weaknesses, and that AI mainly makes existing methods faster and cheaper. That means the basics matter more, not less, and that the time you have to spot an intruder is shrinking.

This playbook is for UK business and IT leaders. It covers the controls that still stop most ransomware, how to detect and respond at speed, how to prepare your plan, your people and your ransom decision, and a plan for this week, this month and this quarter.



The Transputec team
Transputec

INTRODUCTION

Three things decide how a ransomware attack ends.

Attackers are getting quicker at the middle of an attack: exploring the network, stealing credentials and preparing to encrypt. The organisations that come through well have done three things in advance.

Shut the easy doors

Phishing-resistant MFA, fast patching of internet-facing systems, least privilege and segmentation stop most attacks before they start.

Spot the quiet days

Intruders often spend days preparing. Alerts on new admin accounts, credential theft and backup tampering give you time to act.

Be able to recover

Backups the attacker cannot reach, a tested restore, a rehearsed plan and a ransom decision process agreed before you need it.

Ten days inside. Twenty-six minutes to encrypt.

In the school-estate attack, the intruder spent from 10 to 19 September preparing. The encryptor itself ran from 05:07 to 05:33. Detection that only notices the last step is too late.

01

PART 01

What happened.

A national warning and a real attack, published on the same day.

01 The NCSC's judgement

02 The school-estate attack, day by day

03 What is proven and what is not

WHAT HAPPENED

A warning and an example on the same day

> **Attacks are getting cheaper and quicker to adapt, while still relying on familiar gaps.**

The NCSC's Annual Review 2026 covers September 2025 to August 2026.[1] Among its key judgements, it says it is highly likely that AI-powered malware will have been used in a ransomware attack on UK critical national infrastructure by 2028. Highly likely is a formal term on the scale UK intelligence uses for probability, one step below almost certain.

The review is measured about what AI changes. It judges that AI will mainly increase the speed, scale and efficiency of existing attack methods rather than run attacks end to end, and that human operators remain essential. Its incident team handled 337 incidents in the year, 80 of them nationally significant, and most successful compromises still used known vulnerabilities, stolen credentials or social engineering.[1]

Also on 3 November, Bitdefender published its analysis of an attack by a 3AM ransomware affiliate on a UK school estate.[2] Between 10 and 19 September 2026 the intruder stole backup credentials, created new domain admin accounts, linked separate domains with new trusts, took finance files and then encrypted about 37 machines.

What drew attention was the pattern. Commands contained slips typical of language model output, such as Linux-style syntax inside Windows PowerShell and API calls that did not match the vendor's documentation. Retries came 40 to 101 seconds apart regardless of how much had changed, which looks like a loop feeding command output back to a model.

Bitdefender is clear about the limits. It rates model-written commands as strongly supported, but says a person copying between a shell and a chat window cannot be excluded, and that an attack with no human involvement is unsupported. Initial access is unknown and the tools were conventional. As a security vendor, it also has a commercial interest. We treat the AI element as suspected, not proven.

Taken together, the message is not that ransomware has become unstoppable. It is that attacks are getting cheaper and quicker to adapt, while still relying on familiar gaps. The NCSC's chief executive urged organisations to invest with urgency.[3] For most, that means applying the basics with less slack and spotting intruders during the days of preparation.

THE ATTACK, DAY BY DAY

Ten days in a UK school estate

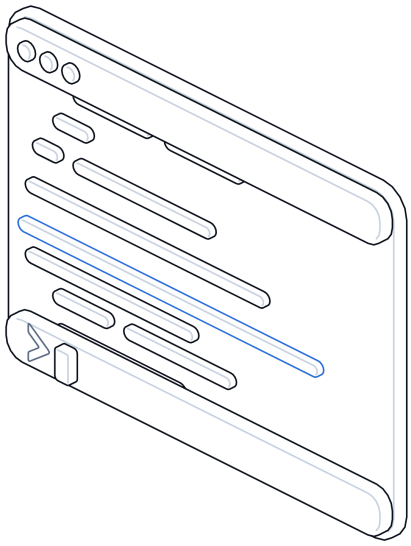
Dates and times are as reported by Bitdefender, in UTC. Initial access was not observed.[2]

DATE (2026)	WHAT THE ATTACKER DID	WHAT IT TEACHES
10 to 11 Sep	Ran a modified public script to pull saved credentials from three backup servers.	Backup servers are an early target. Isolate them and their accounts.
12 Sep	Tried to add an antivirus exclusion, downloaded Mimikatz, checked Domain Admins.	Alert on exclusion changes and known credential tools.
13 Sep	Dropped portable Python, listed service accounts and domain trusts.	Block interpreters on machines that never need them.
14 to 15 Sep	Created two accounts in Domain Admins, zipped and uploaded finance files.	Alert on any new privileged account within minutes.
18 Sep	Built two-way trusts between three separate domains.	Put trusts under change control and alert on changes.
19 Sep	Endpoint protection removal blocked. Encryptor ran 05:07 to 05:33.	Tamper protection held. Controls must not depend on human speed.

THE NCSC'S VIEW

Four judgements worth reading twice

From the NCSC Annual Review 2026, published 3 November 2026.[1]



01 **Highly likely by 2028**

AI-powered malware will have been used in a ransomware attack on UK critical national infrastructure.

02 **Faster, not different**

AI will mainly speed up and scale existing methods, rather than autonomously carry out end-to-end attacks.

03 **A race to patch**

AI-assisted vulnerability discovery means defenders will face pressure to shorten patch timelines.

04 **A widening divide**

Organisations with legacy technology and limited resources may struggle to keep pace and become more attractive targets.

02

PART 02

Shut the easy doors.

The basics still stop most attacks. Then make sure you see the ones that get through.

01 Six basics, done properly

02 Backups the attacker cannot reach

03 Detection and response at speed

THE BASICS

Six controls that still stop most ransomware

Drawn from NCSC guidance and the lessons of the school-estate attack.[4,2]

01 Phishing-resistant MFA

On every remote access point, email and admin login. Use passkeys or hardware keys where supported, including for suppliers.[4]

02 Patch the edge first

Fix known flaws in VPNs, firewalls and other internet-facing systems immediately, then servers and endpoints.[4]

03 Backups that survive

At least one copy offline or immutable, with credentials no domain account holds, and restores tested regularly.[5]

04 Least privilege

Separate admin accounts used only for admin work. Scope backup and service accounts to one domain or system.

05 Segmentation

Allow remote execution tools, remote registry and admin shares only from known management hosts.

06 Cover every machine

Endpoint detection on every server and laptop. An unmanaged host hid who ran the commands in this attack.[2]

01



Backups the attacker cannot reach

Attackers go for backups first because a working restore removes their leverage. Design backups on the assumption that domain admin is already lost.

WHY IT MATTERS

In the school-estate attack, backup credentials were stolen on day one and system backups were deleted during encryption.[2]

WHAT GOOD LOOKS LIKE

One copy offline or immutable at all times. The NCSC notes that an offline copy cannot be hit by the same incident.[5]

HOW TO TEST

Each quarter, restore a whole critical system, not a single file, into an isolated network. Time it and record what broke.

WHAT TO MEASURE

Time to restore your top five systems, share of backups that are immutable, and the date of the last full test.



OWNER

Infrastructure lead, with the backup supplier

Bring this to the monthly review, with a date for each action.

DETECTION AND RESPONSE

Act in minutes, not at the next meeting

When an attacker can try a new step every minute or so, the gap between alert and action is what counts.

Detect the preparation

Alert on new privileged accounts, new domain trusts, saving of registry credential stores, antivirus exclusions and credential tools.

Triage around the clock

Someone, in house or a managed service, watches alerts at night and weekends. This encryption started at 05:07.

Contain without waiting

Pre-approve actions such as isolating a machine, disabling an account or blocking a subnet, so responders can act at once.

Scope and preserve

Work out which accounts, systems and data are affected, and keep logs before anything is rebuilt.

Recover cleanly

Rebuild from known-good images, reset privileged and service credentials, and restore from backups checked for tampering.

> **Bitdefender's advice: favour controls that stop an action whatever its speed or volume, rather than trying to race a machine.**[2]

IN PRACTICE

Three illustrative organisations

GROUP OF 12 SCHOOLS

Separate domains, one small IT team

THE GAP

One admin workstation holds domain admin passwords for every school, plus backup server logins.

THE FIX

Separate admin accounts per domain, used only from dedicated admin machines. Trusts under change control.

THE CHECK

A test trust or admin account triggers an alert to the managed service within minutes.

WATCH OUT

Old Windows 10 PCs and Server 2012 R2 machines that no longer receive security fixes.

REGIONAL MANUFACTURER, 400 STAFF

Production runs on a few servers

THE GAP

Backups on the same domain, reachable with the same admin account as production.

THE FIX

Immutable backup copy with separate credentials, and production network segmented from office systems.

THE CHECK

A quarterly restore of the planning system is timed against the agreed recovery target.

WATCH OUT

Factory systems that cannot run endpoint agents need network monitoring instead.

PROFESSIONAL SERVICES FIRM, 80 STAFF

Cloud first, managed IT supplier

THE GAP

Supplier remote access tool with a shared login and no MFA.

THE FIX

Named supplier accounts with phishing-resistant MFA, access logged and reviewed monthly.

THE CHECK

Supplier confirms out-of-hours monitoring and authority to isolate devices.

WATCH OUT

Cloud data still needs its own backup. Sync is not a backup.

THREAT HUNTING

Five things to look for this month

Indicators reported from the school-estate attack. Use them to test whether your alerts would fire.[2]

01 **Probe and proof files**

Files, tasks or outputs with names like psexec-ok, da_proof or VEEAMPROBE, and numbered scripts that log their own results.

02 **New domain trusts**

Any trust you did not approve, and any use of netdom to create or change one.

03 **Credential store copies**

Commands saving the SAM, SECURITY or SYSTEM registry hives, and attempts to dump LSASS memory.

04 **Portable interpreters**

Python or other interpreters dropped on workstations that have no reason to run them.

05 **Unexpected admins**

Domain Admins membership compared against an approved list. Plausible names such as backup service accounts deserve a second look.

REMEMBER

These come from one attack. They are a test of your detection, not a complete list.

03

PART 03

Ready for the bad day.

Decide now how you will respond, communicate and handle a ransom demand.

01 Plan and exercise

02 The ransom decision in the UK

03 Your plan and your questions

INCIDENT RESPONSE

Build a plan people can use at 5am

A ransomware plan should work when email, files and the directory are all down.

01 Keep it short and offline

One or two pages: who decides, who to call, where to meet. Printed copies and contacts held off the network.

02 Name decision-makers and deputies

Include technical staff alongside senior leaders, as the NCSC recommends for ransom decisions.[6]

03 Line up help before you need it

Insurer's incident panel, an NCSC-assured incident response provider, legal advice and your key suppliers.

04 Exercise at least twice a year

NCSC Exercise in a Box is free and includes ransomware scenarios. Include an out-of-hours start.[7]

05 Rehearse the restore

Run a real restore alongside the tabletop. A plan that has never restored a system is a hope, not a plan.

REMEMBER

Decide in advance who can authorise isolating systems, contacting the attacker and talking to the press.

THE RANSOM DECISION

Paying in the UK: where things stand

Status as at early November 2026. The payment proposals are not yet law. Check for changes before you rely on this.

QUESTION	CURRENT POSITION	STATUS
Who decides?	The victim. The NCSC strongly discourages paying and says payment does not guarantee data back.[6]	Guidance
Sanctions	Paying a sanctioned person or entity can breach UK financial sanctions. The government does not condone payments.[8]	Law in force
Public sector and CNI	Targeted ban proposed for public bodies, including councils, NHS and schools, and regulated CNI.[9,10]	Proposal, not yet law
Everyone else	Proposed regime would require victims to report an intention to pay before paying.[9]	Proposal, not yet law
Reporting	Proposed initial report to government within 72 hours of an attack, fuller report within 28 days.[9]	Proposal, not yet law
Data protection	Notifiable personal data breaches go to the ICO within 72 hours. Paying does not reduce a penalty.[6,11]	Law in force

COMMUNICATIONS AND INSURANCE

Talk clearly, and know your cover

Two areas that are hard to sort out in the middle of an incident.

Prepare holding statements

Draft short messages now for staff, customers, parents or patients, regulators and suppliers. Agree an out-of-band channel in case email is down.

Speak with one voice

One spokesperson, with legal review. Do not speculate about the attacker, the data taken or payment.

Read your policy now

Does it cover extortion, business interruption and incident response? How fast must you notify? Must you use the insurer's panel?

Check what you told them

Insurers ask about MFA, backups and endpoint protection. Make sure your proposal answers are still true today.

> The NCSC advises telling your insurer or broker promptly, using an out-of-hours line or app if one is available.[6]

YOUR PLAN

This week, this month, this quarter

Owners are suggestions. Adjust them to your structure.

WHEN	ACTIONS	OWNER
This week	Check MFA on all remote access, email and admin logins. Confirm one backup copy is offline or immutable.	IT lead
This week	List who can approve isolation out of hours. Print the incident contact sheet.	Head of IT
This month	Patch internet-facing systems. Set alerts for new admins, new trusts and backup changes. Run the hunt checks.	Security lead
This month	Review insurance cover and notification steps. Draft holding statements. Ask suppliers the questions overleaf.	Finance and comms
This quarter	Separate admin accounts, segment backups and management, retire unsupported systems. Endpoint agents everywhere.	Infrastructure lead
This quarter	Run a ransomware exercise with a full restore. Report results and remaining risks to the board.	IT director

FOR LEADERS AND SUPPLIERS

Questions to ask this month

Ask them out loud. Vague answers are the finding.

FOR THE BOARD

- ? If we were encrypted at 5am on Sunday, who would know, and who could act?
- ? When did we last restore a whole critical system, and how long did it take?
- ? Have we agreed how we would decide on a ransom demand, and who is in the room?

FOR IT AND SECURITY SUPPLIERS

- ? Who watches our alerts out of hours, and can they isolate devices without waiting for us?
- ? Can any account you hold delete or change our backups?
- ? How fast would you tell us about a new admin account or domain trust?

CHECKLIST

Is your organisation ready?

Tick what is true today. Anything blank is your next action.

- [ ] **Phishing-resistant MFA on remote access, email and admin**
  Including supplier accounts.

- [ ] **Internet-facing systems patched quickly**
  Known exploited flaws fixed in days.

- [ ] **One backup copy offline or immutable**
  With credentials no domain account holds.

- [ ] **Full restore tested this quarter**
  Timed against the recovery target.

- [ ] **Separate, scoped admin accounts**
  No daily use, no single account across every domain.

- [ ] **Alerts on new admins, trusts and backup changes**
  Watched around the clock.

- [ ] **Incident plan printed and exercised**
  Including an out-of-hours start.

- [ ] **Ransom decision process and insurance reviewed**
  Owners, advisers and reporting steps agreed.

GLOSSARY

Words worth knowing

Ransomware

Malicious software that encrypts systems, usually paired with data theft and a demand for payment.

Affiliate

A criminal who rents a ransomware brand's tools and shares the proceeds with its operators.

Critical national infrastructure

Services the UK relies on, such as energy, water, health and transport.

Agentic loop

Software that feeds results to an AI model, which then chooses the next action.

Domain controller

A server that manages accounts and logins for a Windows network.

Domain trust

A link that lets accounts in one Windows domain be used in another.

Immutable backup

A backup copy that cannot be changed or deleted for a set period, even by an administrator.

Endpoint detection

Software on each device that records activity and can block or isolate threats.

Living off the land

Using tools already built into Windows, which makes attacks harder to spot.

Highly likely

A UK intelligence probability term, one step below almost certain.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

1 NCSC, Annual Review 2026: The State of the Cyber Nation, 3 Nov 2026. ncsc.gov.uk/collection/annual-review-2026

2 Bitdefender, 3AM Hits European Schools: A Hybrid AI Ransomware Attack, Part Human, Part Agentic Loop, 3 Nov 2026. bitdefender.com/en-us/blog/businessinsights/3am-ransomware-hybrid-ai-attack

3 The Register, Britain on notice: AI-powered ransomware attacks to arrive by 2028, 3 Nov 2026. theregister.com/security/2026/11/03/britain-on-notice-ai-powered-ransomware-attacks-to-arrive-by-2028/5307200

4 NCSC, Mitigating malware and ransomware attacks (guidance). ncsc.gov.uk/guidance/mitigating-malware-and-ransomware-attacks

5 NCSC, Offline backups in an online world (blog), 13 Aug 2019. ncsc.gov.uk/blog-post/offline-backups-in-an-online-world

6 NCSC with ABI, BIBA and IUA, Guidance for organisations considering payment in ransomware incidents, 14 May 2024. ncsc.gov.uk/guidance/organisations-considering-payment-in-ransomware-incidents

7 NCSC, Exercise in a Box. ncsc.gov.uk/information/exercise-in-a-box

8 OFSI (HM Treasury), Financial sanctions guidance for ransomware, updated 28 Jan 2026. gov.uk/government/publications/financial-sanctions-guidance-for-ransomware

9 Home Office, Ransomware legislative proposals: government response, 22 Jul 2025. gov.uk/government/consultations/ransomware-proposals-to-increase-incident-reporting-and-reduce-payments-to-criminals

10 The Register, UK to ban ransomware payments by public sector organizations, 22 Jul 2025. theregister.com/2025/07/22/uk_to_ban_ransomware_payments/

11 ICO, Personal data breaches: a guide. ico.org.uk/for-organisations/report-a-breach/personal-data-breach/personal-data-breaches-a-guide/

TRANSPUTEC

Ready before the bad day?

Transputec helps UK organisations harden identity and backups, watch for intruders around the clock and rehearse the response, so a ransomware attack stays an incident rather than a crisis.

Book a ransomware readiness review

transputec.com

NEXT IN THE SERIES

No. 10 · Attacks at machine speed





HOT TOPICS · AI-DRIVEN INTRUSION

Attacks at machine speed.

Attackers now point AI agents at your network and let them probe, exploit and move in parallel. A practical playbook for shrinking the target and responding in minutes, not days.

INSIDE

Contents

A practical guide to defending against attackers who use AI agents: what was reported, how to shrink what they can reach, and how to detect and contain an intrusion that moves in minutes.

Foreword 03

Introduction 04

01 What happened 06

02 Shrink the target 09

03 Contain at speed 14

Sources 24

FOREWORD

The weaknesses were old. The pace was not.

At the end of October 2026, CrowdStrike reported that a China-nexus group had used an agentic AI penetration testing framework called ARTEX against more than 200 organisations in 11 days. A week earlier, Microsoft described a separate China-aligned group using the same framework to reach Microsoft 365 tenants through a compromised supplier application.

Look closely at how these intrusions worked and very little is new. Unrotated keys from an old directory export. A login that did not check signatures. A service left open without authentication. Password spraying. What changed is that one operator could run many attacks at once, while software tried every path in parallel and switched when one failed.

This playbook is written for UK business and IT leaders and the teams and suppliers who run their security. It covers what was actually reported, what is confirmed and what is not, and then the practical work: reduce what is exposed, harden identities, detect behaviour rather than known files, and agree in advance who can stop an attack at three in the morning.



The Transputec team
Transputec

INTRODUCTION

Three ways to keep pace with an AI attacker.

You do not need to match an attacker's AI tool for tool. You need fewer openings, faster signals and decisions that are already made before the alert fires.

Shrink the target

Find everything you expose to the internet, remove what does not need to be there and fix the rest quickly.

Harden identities

Phishing-resistant sign-in, rotated keys and least privilege for people, services and supplier apps.

Contain in minutes

Alert on behaviour, let pre-approved actions run automatically and keep a named human for the big decisions.

An AI agent does not get tired, and it does not wait until Monday.

Defence that depends on someone noticing a ticket next morning is already too slow. The answer is fewer doors, sharper alerts and containment you have agreed in advance.

01

PART 01

What happened.

Two vendor reports in October 2026 described AI agents running intrusions at a pace human teams cannot match.

01 The VAPOR PANDA campaign

02 Microsoft and Storm-0940

03 Confirmed versus claimed

WHAT HAPPENED

One operator, many agents

> **The weaknesses were old. The speed was new.**

On 29 October 2026 CrowdStrike reported that a China-nexus group it tracks as VAPOR PANDA had used ARTEX, an agentic AI penetration testing framework, against more than 200 organisations in at least 14 countries over an 11-day window starting 17 October.[1] CyberScoop, reporting an interview with CrowdStrike, said about 140 sensitive targets had been compromised and that about 70% of targets were confirmed or showed moderate-confidence signs of intrusion.[2]

Those figures need care. CrowdStrike's published post confirms post-exploitation at nine organisations, with password spraying or credential scanning against at least 12 more.[1] The 140 figure mixes confirmed and likely victims. All figures, and the China link, are CrowdStrike's; no government has published its own count.

The method is the real story. One controller ran many engagements at once, stepping in only at decision points, while agents tried web apps, cloud, containers, Active Directory and VPNs in parallel. The agents ran mainly on DeepSeek, with a second commercial model CrowdStrike could not confirm.[1]

CrowdStrike says human operators typically ran up to 40 commands an hour; with ARTEX it saw over 1,500.[2]

The ways in were familiar. An unsigned SAML assertion and an XML flaw gave cloud admin rights at a US pharmaceutical firm. An orchestration service with no authentication gave root in a container. Keys from a 2022 directory export, never rotated, let the agent forge an admin token at a Greek government body. The operator even asked the agents to find machines without endpoint protection.[1,3]

It was not the only campaign. On 21 October Microsoft said a China-aligned group, Storm-0940, had used ARTEX, an open-source framework, against hundreds of organisations, sometimes reaching privileged cloud access in under three hours, and used stolen ConnectWise app identities to try more than 2,250 tenants.[4,5] In November 2025 Anthropic reported a Chinese state-sponsored group using Claude Code against roughly 30 targets, succeeding in a small number, with AI doing 80% to 90% of the work.[6]

The NCSC said on 3 November that AI is highly likely to increase the scale and efficiency of vulnerability exploitation within two years.[7] The lesson is not that attacks are unstoppable. Old weaknesses are found and used faster, so your time to fix or contain them is shrinking.

CONFIRMED OR CLAIMED

What we know, and how sure we are

Early reporting on live campaigns changes. This is the state of the evidence on 4 November 2026.[1,2,4]

CLAIM	WHAT THE SOURCE SAYS	STATUS
200+ organisations	CrowdStrike: at least 14 countries, from 17 October, over 11 days.	Published by CrowdStrike. Not independently verified.
About 140 compromised	CrowdStrike interview with CyberScoop. About 70% confirmed or moderate confidence.	Reported. Mixes confirmed and likely victims.
Nine intrusions	CrowdStrike blog: access, a known backdoor and follow-on reconnaissance.	Confirmed by CrowdStrike.
China link	CrowdStrike linked the ARTEX controller to VAPOR PANDA infrastructure.	Vendor assessment, not a government attribution.
AI models used	Mainly DeepSeek, plus a second commercial model.	Second model unconfirmed.
Storm-0940	Microsoft: ARTEX used to try more than 2,250 tenants via a supplier app.	Separate campaign. Data theft not established.

02

PART 02

Shrink the target.

An agent can only try the doors it can find. Close the ones you do not need and lock the rest properly.

01 External exposure management

02 Fast fixes at the edge

03 Identity hardening

EXPOSURE MANAGEMENT

See yourself the way the agent does

ARTEX tried many attack paths at once. Every service you remove is one fewer path to try.

01 Scan from the outside

Run an external scan of every domain, IP range and cloud account you own. Register for the NCSC's free Early Warning service, which alerts UK organisations to exposed services and signs of compromise.[8]

02 Reconcile with your inventory

Anything the scan finds that is not on your list gets an owner within a week, or gets switched off.

03 Remove what does not need to be there

The NCSC's advice is blunt: do not connect technology to the internet unless it needs to be.[7] Start with admin pages, test sites, open file directories and orchestration consoles.

04 Check authentication on what is left

No unauthenticated services, and single sign-on set to reject unsigned SAML assertions.[1]

05 Make it continuous

Scan weekly, alert on any new exposure and review the list with owners every month.

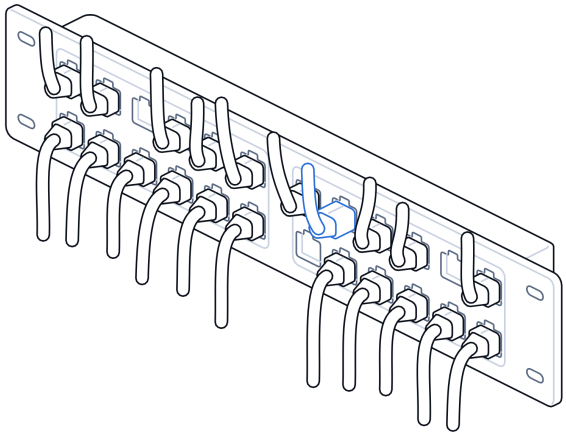
REMEMBER

Ask your supplier for the external view of your organisation in writing. If they cannot produce it, nobody is watching it.

FAST FIXES

Fix the internet-facing systems first

Our playbook No. 06 covers the patch gap in depth. Against machine-speed attackers, four points matter most.



01 **Rank by reachability**

Internet-facing systems and anything that handles sign-in come before everything else in the queue.

02 **Mitigate the same day**

If an exploited flaw has no fix yet, apply the vendor's workaround or take the service offline.

03 **Include the long-lived servers**

CrowdStrike singles out internet-facing appliances and long-lived Linux servers that drift out of date.[1]

04 **Look for compromise after**

A patch closes the door but does not remove a web shell already planted. Check before you close the ticket.

IDENTITY HARDENING

Six rules for identities under automated attack

The October campaigns turned passwords, keys and app permissions into access. These rules come from the vendor reports.

01 **Phishing-resistant sign-in for people**

Passkeys or hardware keys for every user and admin, so a sprayed or stolen password is not enough.

02 **Rotate keys after any exposure**

Signing keys, service credentials and secrets, including those in old backups and directory exports.[1]

03 **Least privilege for apps**

A compromised high-privilege app can reach far beyond its job. Cut supplier app permissions to what they need.[4]

04 **Lock down cloud metadata and roles**

Require IMDSv2 and limit which roles can run commands across many instances.[1]

05 **Alert on identity changes**

New app credentials, consent grants and privileged role assignments should alert within minutes.[4]

06 **Blunt the spray**

Microsoft saw failures peak at 2,900 a minute. Use smart lockout and conditional access, and block legacy sign-in.[4]

01

Treat every connected app as an identity

In the ConnectWise case, stolen app identities reached customer tenants without any user signing in. Supplier apps deserve the same scrutiny as admin accounts.

WHY IT MATTERS

An app with broad rights can read mail, change roles and add credentials, and no user ever sees a prompt.

WHERE TO START

List every enterprise app and consent grant with high privileges. Search by application ID, not display name.

WHAT TO CHANGE

Remove unused apps, cut permissions, require admin consent, rotate secrets and set alerts on credential changes.

WHAT TO MEASURE

Number of high-privilege apps, share with a named owner, and minutes needed to disable one.

OWNER

Identity lead, with procurement

Bring this to the monthly review, with a date for each action.

03

PART 03

Contain at speed.

Assume something gets in. The race is between the agent's next step and your first decision.

01 Detection that watches behaviour

02 Automated containment, human approval

03 Rehearse the race

DETECTION

Behaviour signals worth an alert

Agents change tools and paths quickly, so watch for patterns of behaviour rather than known files.[1,4]

SIGNAL	WHAT IT LOOKS LIKE	FIRST RESPONSE
Sign-in bursts	Thousands of failures across many accounts in minutes from few sources.	Block sources, confirm lockout works, check for any success.
Machine-pace commands	Dozens of reconnaissance commands a minute from one host or account.	Isolate the host and suspend the account pending review.
Coverage checks	Process or folder listings that look for security tools.	Treat as hands-on intrusion. Hunt for unprotected hosts.
New app powers	Secrets added to apps, self-assigned admin roles, new consent grants.	Disable the app, preserve logs, revoke the change.
Web shells and tunnels	New script files on web servers, unexpected tunnelling tools.	Isolate the server and collect evidence before rebuilding.
Bulk secret reads	Many reads from a secrets store in a short time.	Rotate the secrets and review the identity used.

CONTAINMENT

Automated containment with human approval

Small, reversible actions run on their own. Big ones need a named person who can answer within minutes, day or night.

Detect

A high-confidence behaviour rule fires, enriched with who, what and where.

Contain within limits

Pre-approved actions run at once: isolate a laptop, end a session, block an address. Each can be undone.

Approve the big moves

Disabling a service account, isolating servers or cutting supplier access needs a named approver, reachable around the clock.

Investigate and widen

Scope the intrusion and hunt for the same pattern on other hosts, accounts and tenants.

Recover and tune

Restore, rotate credentials, review false alarms and adjust the rule.

> **Agree in writing which actions your SOC may take without asking, and who answers the phone at 3am for the rest.**

AI ON DEFENCE

Using AI on defence, responsibly

AI helps defenders sort, summarise and test faster. It needs the same limits you would set for any powerful account.

Triage and summarise

Let AI group alerts and draft incident summaries so analysts spend time on decisions, not reading.

Test yourself first

Authorised, scoped testing of your own exposure. The NCSC suggests validating configurations, possibly with agentic tools.[9]

Fence the agent

Give each defensive agent its own identity, minimal short-lived permissions, a sandbox and full logging.[9]

Keep a stop button

Humans in or on the loop, with real-time alerts and the ability to halt the agent quickly.[9]

> **Do not buy AI because the attacker has it. Buy faster, better decisions, and measure whether you got them.**

TABLETOP

A 90-minute exercise for a fast-moving intrusion

Build on the NCSC's free Exercise in a Box and add these injects.[10]

01 **Set the scene**

02:10 on a Saturday. Your MSP sees thousands of failed sign-ins a minute, then one success through a supplier app.

02 **Inject one, minute 15**

New credentials are added to that app and it assigns itself an admin role in your tenant.

03 **Inject two, minute 30**

A web shell appears on a public server and the attacker starts listing hosts without endpoint protection.

04 **Decide**

Who can disable the supplier app, isolate servers and brief the board? Time each decision.

05 **Debrief**

Record decision times, gaps in authority and missing logs. Fix the top three within a month.

REMEMBER

The number that matters is minutes from first alert to containment. Write it down and try to halve it.

IN PRACTICE

Three organisations, three fast intrusions

LAW FIRM, 120 STAFF

Password spray against Microsoft 365

THE RISK

Some accounts still on password-only sign-in, including a shared mailbox.

THE FIX

Phishing-resistant MFA, legacy sign-in blocked, smart lockout and a sign-in burst alert.

THE CHECK

A simulated burst raises an alert and a call within ten minutes.

WATCH OUT

Service accounts quietly excluded from MFA rules.

MANUFACTURER WITH CLOUD WORKLOADS

Old keys, new attacker

THE RISK

Years-old directory exports with live keys sitting on a file share.

THE FIX

Keys rotated, old exports deleted, IMDSv2 required, command rights narrowed.

THE CHECK

Quarterly scan of shares and repositories for secrets.

WATCH OUT

Rotation can break integrations. Plan and test it.

CHARITY WITH AN MSP

Supplier app with too much power

THE RISK

A backup app held broad Microsoft 365 rights that nobody reviewed.

THE FIX

Permissions cut, alerts on app credential changes, MSP allowed to disable it.

THE CHECK

Disable the app in a test and time how long it takes.

WATCH OUT

Backups pause while the app is off. Agree a fallback.

YOUR PLAN

This week, this month, this quarter

Owners are suggestions. Adjust them to your structure.

WHEN	ACTIONS	OWNER
This week	Run an external scan and register for Early Warning. Remove exposed admin pages and unauthenticated services.	IT lead
This week	Review high-privilege apps and consent grants. Confirm MFA on every account, including service accounts.	Identity lead
This month	Rotate old keys and secrets. Turn on alerts for identity changes and sign-in bursts. Report EDR coverage.	Security lead
This month	Agree containment rules with your MSP or SOC, with named approvers around the clock.	Head of IT
This quarter	Run the tabletop. Measure minutes to contain. Move to continuous exposure monitoring.	Head of IT
This quarter	Report exposure, coverage and containment times to the board, with dated actions.	IT director

FOR LEADERS

Questions for your board and your MSP or SOC

Ask them out loud. Vague answers are the finding.

FOR THE BOARD

- ? Do we know everything we expose to the internet, and how fast is a new exposure spotted?
- ? If an attack began at 2am on Saturday, how many minutes until someone could contain it?
- ? Which suppliers hold privileged access to our cloud, and could we cut it off quickly?

FOR YOUR MSP OR SOC

- ? Which actions can you take without calling us, and how fast?
- ? Do you alert on sign-in bursts, new app credentials and role changes?
- ? What share of our servers, including internal ones, report to EDR?
- ? How do you use AI in your service, and who checks its decisions?

CHECKLIST

Are you ready for machine speed?

Tick what is true today. Anything blank is your next action.

- [ ] **External exposure scanned weekly**
  And every finding has an owner.

- [ ] **Registered for NCSC Early Warning**
  With alerts going to someone who acts.

- [ ] **No unauthenticated services on the internet**
  SAML signatures validated everywhere.

- [ ] **Phishing-resistant MFA for people**
  Legacy sign-in blocked.

- [ ] **High-privilege apps reviewed**
  Unused removed, the rest with owners and alerts.

- [ ] **Old keys and secrets rotated**
  Including backups and directory exports.

- [ ] **EDR on every server and laptop**
  With an alert when one stops reporting.

- [ ] **Containment rules agreed and rehearsed**
  Named approvers, timed in a tabletop.

GLOSSARY

Words worth knowing

Agentic AI

AI that plans and carries out multi-step tasks, using tools, with little human direction.

ARTEX

An open-source AI penetration testing framework that both reported campaigns used.

Penetration testing

Authorised simulated attacks to find weaknesses before criminals do.

Exposure management

Continuously finding and reducing what your organisation exposes to the internet.

Password spraying

Trying a few common passwords against many accounts to avoid lockouts.

SAML

A standard for single sign-on. Assertions must be signed and checked.

Service principal

The identity an application uses to access your cloud tenant.

EDR

Endpoint detection and response: software that watches device behaviour and can isolate a host.

Web shell

A malicious script placed on a web server to give an attacker remote control.

Human in the loop

A person must approve key actions before an automated system takes them.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

1 CrowdStrike, VAPOR PANDA Uses AI-Driven ARTEX to Scale a Global Espionage Campaign, 29 Oct 2026. crowdstrike.com/en-us/blog/vapor-panda-uses-artex-to-scale-global-campaign/

2 CyberScoop, China-backed threat group used agentic AI pentesting tool to compromise 140 sensitive targets in 11 days, 30 Oct 2026. cyberscoop.com/china-vapor-panda-agentic-ai-artex-campaign-crowdstrike/

3 CSO Online, Armed with AI, hackers target endpoint security blind spots, raising stakes for CISOs, 3 Nov 2026. csoonline.com/article/4243816/

4 Microsoft Security Blog, AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise, 21 Oct 2026. microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-agentic-ai-connectwise-supply-chain-compromise/

5 CyberScoop, Microsoft pins ConnectWise supply-chain attack to China-state aligned threat group, 21 Oct 2026. cyberscoop.com/microsoft-attributes-connectwise-supply-chain-attack-china-storm-0940/

6 Anthropic, Disrupting the first reported AI-orchestrated cyber espionage campaign, 13 Nov 2025. anthropic.com/news/disrupting-AI-espionage

7 NCSC, Cyber chief: UK facing AI-powered attacks on critical infrastructure within two years, 3 Nov 2026. ncsc.gov.uk/news/cyber-chief-uk-facing-ai-powered-attacks-on-critical-infrastructure-in-two-years

8 NCSC, Early Warning service. ncsc.gov.uk/information/early-warning-service

9 NCSC, Managing the cyber risk of agentic AI (interim blog), 20 Aug 2026. ncsc.gov.uk/blogs/managing-the-cyber-risk-of-agentic-ai

10 NCSC, Exercise in a Box. ncsc.gov.uk/information/exercise-in-a-box

TRANSPUTEC

Ready for attacks at machine speed?

Transputec helps UK organisations map and shrink their external exposure, harden identities and supplier apps, and run round-the-clock detection with containment you have agreed in advance.

Book an exposure review

transputec.com

NEXT IN THE SERIES

No. 11 · One code, full access





PLAYBOOK NO. 11 · IDENTITY AND PHISHING

One code, full access.

Phishing that gets past MFA by sending staff to a genuine Microsoft sign-in page. How device code phishing works, and how to shut it down in your tenant.

INSIDE

Contents

A practical guide to device code phishing in Microsoft 365: how the trick works, why MFA does not stop it, and what to do this week, this month and this quarter.

Foreword 03

Introduction 04

01 What happened 06

02 Close the flow 10

03 Prepare your people 16

Sources 24

FOREWORD

Your staff did everything right. The attacker still got in.

We have spent years teaching people to check the web address before they sign in. Device code phishing turns that advice against them. The victim is sent to a real Microsoft page, on a real Microsoft address, and asked to type in a short code. They sign in, approve their MFA prompt and carry on with their day.

What they have actually done is approve a sign-in for a device that belongs to an attacker. No password is stolen. No fake login page is involved. The attacker simply receives a working session to the victim's mailbox, files and Teams chats.

This technique has moved from targeted espionage to a commodity sold by subscription, and it featured again in threat roundups at the start of November 2026. The fix is not glamorous. Most organisations can switch off the sign-in method that makes it possible, prepare a fast response and give staff one clear rule. This playbook shows how.



The Transputec team
Transputec

INTRODUCTION

A real page, a fake reason.

Device code phishing abuses a legitimate Microsoft sign-in method built for televisions, printers and meeting room screens. The attacker supplies the code. The victim supplies the sign-in. This playbook covers three things.



Understand the trick

What device code phishing is, the campaigns behind it, and why multi-factor authentication does not stop it on its own.



Close the flow

Block or tightly restrict device code sign-in with Conditional Access, add stronger controls and know how to respond.



Prepare your people

Real lure examples, a simple rule for staff, help desk scripts and a plan for this week, this month and this quarter.

If you did not start it, do not type the code.

Device code phishing works because people trust the Microsoft page in front of them. The defence is to remove the sign-in method where you do not need it, and to teach one rule where you do.

01

PART 01

What happened.

How an old sign-in method for televisions became one of the busiest phishing techniques of 2026.

01 The trick in plain English

02 How the attack works, step by step

03 The campaigns behind it

THE NEWS

A genuine page, a borrowed session

> **You sign in on Microsoft's real page. The attacker walks away with the session.**

The trick is simple. Some devices, such as smart TVs and meeting room screens, have no proper keyboard. So Microsoft lets them show a short code and ask you to finish signing in on your phone or laptop. An attacker can ask Microsoft for one of these codes too, then send it to you dressed up as a meeting ID, a document code or a security check. Nothing about the page you land on is fake.

You visit a genuine Microsoft page, type the code and sign in as normal, including your MFA prompt. Microsoft then hands access and refresh tokens to the session that asked for the code: the attacker's. The code lasts 15 minutes by default, so lures now generate a fresh one when you click.[1] Because the sign-in really is yours, checking the web address and approving MFA prove nothing here.

This is not new. In February 2025 Microsoft described a group it calls Storm-2372 using fake Teams meeting invitations against government, defence, health and other sectors. In July 2026 Microsoft said it now assesses that group as part of Midnight Blizzard.[2] Proofpoint reported that by September 2025 the technique had spread to widespread campaigns, including by criminal groups.[3]

2026 brought scale. Microsoft linked EvilTokens, a phishing kit sold by subscription from February, to more than 12,000 compromised inboxes in over 10,000 organisations, with the UK among the most affected countries.[4] Microsoft and partners disrupted it in September, and the Metropolitan Police arrested two men in connection with it.[5]

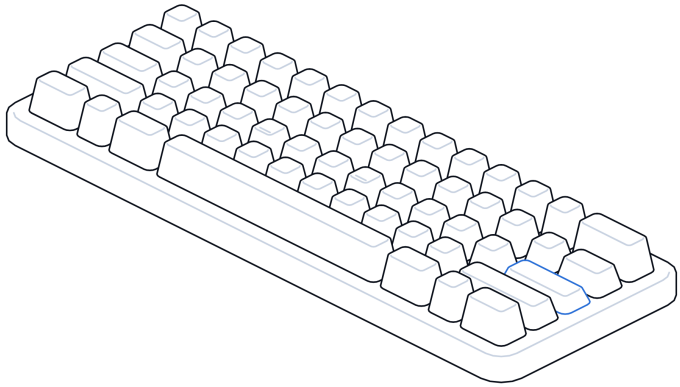
The trade has not stopped. On 29 October Group-IB described MadApe, a separate kit using PDF lures and fake SharePoint, OneDrive, Teams, Adobe and DocuSign pages, with device code components on 97 domains.[6] Weekly threat roundups on 2 November listed device code phishing among the week's active techniques.[7]

The good news is that most staff never need this sign-in method. Microsoft's advice is to get as close as possible to blocking it outright and to allow it only for documented cases such as meeting room devices.[8] That single control, a quick response plan and one clear rule for staff remove most of the risk.

HOW IT WORKS

Four steps from lure to mailbox

Why MFA does not help here: the victim completes MFA themselves, for a session the attacker started.



01 **The attacker asks for a code**

Their tool requests a device sign-in from Microsoft and receives a short user code plus a link to microsoft.com/devicelogin.

02 **The lure delivers it**

An email, PDF, Teams chat or fake document page shows the code as a meeting ID, access code or security check.

03 **The victim signs in for real**

On the genuine Microsoft page they enter the code, their password and their MFA approval. Nothing looks wrong.

04 **The attacker gets the tokens**

The attacker's session receives access and refresh tokens. It can read mail, register a device and keep access after a password reset.

THE CAMPAIGNS

Who has used it, and how

A selection of publicly reported activity. Figures are as reported by each source.

CAMPAIGN	WHAT WAS REPORTED	LURE
Storm-2372[2]	Microsoft, Feb 2025: government, NGOs, defence, health, energy. Later linked to Midnight Blizzard.	Fake Teams meeting invitations after building rapport on WhatsApp, Signal or Teams.
Criminal wave[3]	Proofpoint, Dec 2025: state-aligned and criminal groups, widespread from September 2025.	Salary bonus documents, fake OneDrive shares, fake security prompts.
Huntress cluster[9]	More than 340 organisations in five countries from February 2026.	Construction bids, DocuSign, voicemail, Microsoft Forms.
EvilTokens[4]	Over 12,000 inboxes, 10,000+ organisations. Disrupted September 2026.	44 themes, including invoices, shared files and password expiry.
MadApe[6]	Group-IB, 29 Oct 2026: 155 root domains, 97 with device code parts.	Business PDFs, fake SharePoint, Teams, Adobe and DocuSign pages.

02

PART 02

Close the flow.

Switch off device code sign-in where you do not need it, protect the exceptions and be ready to respond.

01 Block device code flow

02 Handle the exceptions

03 Layer the controls and respond fast

CONDITIONAL ACCESS

Block device code flow in six steps

Microsoft's recommended approach.[8] Conditional Access needs Microsoft Entra ID P1, included in Microsoft 365 Business Premium.

01 Check who uses it today

In Entra sign-in logs, filter Authentication protocol to Device code flow. Note each user, app, location and owner.[10]

02 Look for a Microsoft-managed policy

Many tenants now have a Microsoft-managed 'Block device code flow' policy. Microsoft turns these on after at least 30 days in report-only.[11]

03 Create or adopt the block

All users, all resources, condition Authentication flows set to Device code flow, grant control Block access.

04 Exclude only what you must

Emergency access accounts and named exception groups. Exclude the Device Registration Service resource if devices register this way.

05 Run in report-only first

Review policy impact for a week or two. Talk to the owners of anything that would break.

06 Turn it on and keep watching

Switch to On, then review blocked sign-ins and exception group membership every month.

01



Handling the exceptions

Some Teams Rooms and shared Teams devices need device code flow to register and re-authenticate. So do some admin and developer tools. Scope exceptions tightly.[12]

THIS WEEK

List every device and tool that genuinely needs device code flow, with a named business owner for each.

THIS MONTH

Put Teams device resource accounts in a dedicated exception group. Never exclude broad groups of ordinary users.

THIS QUARTER

Move admin and developer tools to browser or brokered sign-in, and automation to managed identities.

CHECK

An exception covers the whole account, not one app. Alert on any device code use by people outside the exception groups.



OWNER

Microsoft 365 or identity lead

Bring this to the monthly review, with a date for each action.

LAYERED CONTROLS

What each control does, and where it stops

Blocking the flow does most of the work. These controls narrow what is left.

CONTROL	WHAT IT HELPS WITH	ITS LIMIT
Block device code flow	Removes the attack for everyone outside your exception groups.	Does not end sessions already issued. Revoke those separately.
Require compliant or joined devices	An attacker's own laptop fails the device check, so sign-ins are refused.[3]	Needs Intune or equivalent. Exceptions need care.
Phishing-resistant MFA (passkeys, FIDO2)	Stops fake login pages and is Microsoft's recommended MFA.	Does not stop this trick alone: the victim signs in on the real page.
Token protection	Accepts only device-bound tokens for Exchange, SharePoint and Teams on supported devices.[13]	Limited apps and platforms. Pilot in report-only.
Sign-in risk policies	Challenge or block sign-ins from unusual places and anonymous networks.	Needs Entra ID P2. Attackers use local proxies.
Mail and link protection	Safe Links, anti-phishing policies and zero-hour purge catch known lures.	New domains and PDFs slip through for a while.

MONITORING

Five signals worth an alert

Most of these are in Entra sign-in logs and Microsoft Defender. Point your monitoring or managed service at them.

Any device code sign-in

Sign-ins where Authentication protocol is Device code flow, from users outside your exception groups.

Odd locations and hosting networks

Device code sign-ins from cloud hosting providers, anonymisers or countries where you have no staff.

New devices registered

A device registered to a user shortly after a device code sign-in. Storm-2372 used this to keep access.

New inbox rules

Rules that delete, hide or forward mail, often created minutes after the account is taken over.

Unusual mail and file access

Bulk reads, searches for words like password or invoice, and large downloads via Microsoft Graph.

> **Group-IB also suggests linking device code sign-ins with email link clicks in the same few minutes.[6]**

RESPONSE

If someone typed a code they should not have

Move fast. Changing the password alone does not end the attacker's session.

01 Confirm the sign-in

Check the user's sign-in logs for a device code sign-in at the time they entered the code.

02 Revoke sessions

Use Revoke sessions in the Entra admin centre or Revoke-MgUserSignInSession. Consider disabling the account briefly.[14]

03 Remember the one-hour tail

Access tokens last about an hour by default. Microsoft advises revoking and, if needed, temporarily disabling the account.[4]

04 Remove what they added

Delete unknown devices, inbox rules, forwarding, app consents and MFA methods registered during the incident.

05 Check what they did

Review mail sent, files accessed and any messages sent from the account to customers or suppliers.

06 Warn others

Search for the same lure in other mailboxes, purge it, and tell staff what to watch for.

03

PART 03

Prepare your people.

Show staff what the lures look like, give the help desk a script and agree a plan.

01 Real lure examples

02 Scenarios and help desk scripts

03 Your week, month and quarter plan

REAL LURES

What the lure looks like in practice

All four are drawn from published campaigns. Each ends at the genuine microsoft.com/devicelogin page.

The meeting ID that is not

A Teams or webinar invitation tells you to 'enter the meeting code' at a Microsoft page to join. Used by Storm-2372.[2]

The shared document

A SharePoint, OneDrive or DocuSign style page shows a code and a 'Continue to Microsoft' button.[9]

The invoice or voicemail

A PDF payment report, contract or voicemail notice links to a page that hands you a code.[6]

The security check

A message asks you to 're-verify' or confirm a one-time code because your password is expiring.[3]

> **The rule for staff: only type a code at microsoft.com/devicelogin if you are setting up a TV, printer or meeting room device yourself, right now.**

SCENARIOS

Three moments your people will face

FINANCE

The supplier invoice PDF

WHAT HAPPENS

A familiar-looking supplier sends a payment report. The link shows a code and a Microsoft button.

THE RISK

Mailbox takeover, then fake bank detail changes sent to real customers.

THE RIGHT MOVE

Close the page. Report it with the phishing button. Do not type the code.

YOUR CONTROL

Device code flow blocked, plus a payment change call-back rule.

EXECUTIVE ASSISTANT

The invitation to a briefing

WHAT HAPPENS

After friendly messages on WhatsApp, an invite asks them to enter a meeting code at a Microsoft page.

THE RISK

Access to the executive's mail, diary and Teams chats.

THE RIGHT MOVE

Real Teams meetings never need a code typed on a Microsoft sign-in page. Report it.

YOUR CONTROL

Block the flow, and brief executive support staff first.

HELP DESK

The worried caller

WHAT HAPPENS

A user rings: they typed a code from an email ten minutes ago and approved MFA.

THE RISK

An attacker already holds a live session, even if the password changes.

THE RIGHT MOVE

Thank them, revoke sessions at once, escalate to security.

YOUR CONTROL

A written script and the rights to revoke sessions on first call.

HELP DESK SCRIPTS

What to say, and what to do next

Short scripts reduce hesitation. Praise people who report quickly: speed matters more than blame.

SITUATION	WHAT TO SAY	WHAT HAPPENS NEXT
User typed a code	'Thanks for calling straight away. I'm ending your sessions now; you'll need to sign in again.'	Revoke sessions, check logs, escalate to security.
User only saw the lure	'Please don't type the code. Use the Report button and delete it.'	Search for and purge the same message.
Code request on a call	'We never ask you to type a code we send you. I'll call you back on the number we hold.'	Log the call and alert security.
New meeting room device	'IT will sign the room in using its own room account.'	Use the Teams device exception group.
Blocked by the new policy	'That sign-in method is now switched off. Let's find another way to connect.'	Log the tool and its owner for review.

YOUR PLAN

This week, this month, this quarter

A realistic sequence for most UK organisations running Microsoft 365.

WHEN	ACTION	OWNER
This week	Check sign-in logs for device code use. Put a block policy in report-only.	Microsoft 365 lead
This week	Send staff the one rule with the four lure examples. Brief the help desk.	IT lead with comms
This month	Turn the block on with tight exception groups. Test revoking sessions end to end.	Identity lead
This month	Alert on device code sign-ins, new device registrations and new inbox rules.	Security or managed provider
This quarter	Require compliant devices, roll out passkeys and pilot token protection.	IT and security
This quarter	Review exceptions, rerun the help desk drill and report results to the board.	CISO or IT director

ASK THE QUESTION

Questions for the board and your suppliers

Use these at your next leadership meeting and supplier review.

FOR YOUR LEADERSHIP TEAM

- ? Is device code sign-in blocked in our Microsoft 365 tenant, and who approved each exception?
- ? If a director typed a code today, how quickly could we end the attacker's session?
- ? Have our staff been shown what these lures actually look like?

FOR YOUR IT PROVIDER OR MANAGED SERVICE

- ? Do you alert on device code sign-ins, new device registrations and suspicious inbox rules?
- ? Can your help desk revoke sessions on the first call, out of hours?
- ? When will we move from phone and app prompts to phishing-resistant MFA?

CHECKLIST

Is the door closed?

Tick what is in place. Anything blank is your next step.

- [ ] **Device code flow blocked by Conditional Access**
  Report-only first, then on.
- [ ] **Exceptions limited to named groups with owners**
  Teams device resource accounts and documented tools only.
- [ ] **Alerts on device code sign-ins and new devices**
  Plus new inbox rules and forwarding.
- [ ] **A tested way to revoke sessions in minutes**
  Including out of hours.
- [ ] **Staff shown the one rule and real lure examples**
- [ ] **Help desk scripts written and rehearsed**
- [ ] **A roadmap for compliant devices and passkeys**
  With token protection piloted where supported.

See the sources page for Microsoft's guidance on each control.

GLOSSARY

Words worth knowing

Device code flow

A Microsoft sign-in method where one device shows a code and you finish signing in on another. Formally the OAuth 2.0 device authorisation grant.

microsoft.com/devicelogin

The genuine Microsoft page where device codes are entered.

Access token

A short-lived pass, about an hour by default, that lets an app read your mail or files.

Refresh token

A longer-lived token used to get new access tokens without signing in again.

Conditional Access

Microsoft Entra rules that decide who can sign in, from where, on what device and by which method.

Report-only mode

A setting that shows what a Conditional Access policy would do, without enforcing it.

Phishing-resistant MFA

Sign-in methods such as passkeys and FIDO2 keys that cannot be replayed on a fake site.

Token protection

A Conditional Access control that only accepts tokens bound to a registered device.

Revoke sessions

An admin action that invalidates a user's refresh tokens so they must sign in again.

Phishing as a service

Criminal kits sold by subscription, with templates, hosting and dashboards included.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

1 Microsoft Learn, OAuth 2.0 device authorization grant, updated Jun 2026. learn.microsoft.com/entra/identity-platform/v2-oauth2-device-code

2 Microsoft Threat Intelligence, Storm-2372 conducts device code phishing campaign, 13 Feb 2025, updated 31 Jul 2026. microsoft.com/security/blog

3 Proofpoint, Access granted: phishing with device code authorization for account takeover, 18 Dec 2025. proofpoint.com/us/blog/threat-insight

4 Microsoft Security Blog, Unmasking EvilTokens: getting to the root of device code phishing, 22 Sep 2026. microsoft.com/security/blog

5 The Hacker News, Microsoft takes down EvilTokens device-code phishing service, 22 Sep 2026. thehackernews.com/2026/09/microsoft-takes-down-eviltokens-device.html

6 Group-IB, MadApe: the code that opens the door, 29 Oct 2026. group-ib.com/blog/madape-microsoft-device-code-phishing-kit

7 The Hacker News, Weekly recap: critical CVEs, Linux DDoS botnet, device-code phishing, 2 Nov 2026. thehackernews.com/2026/11/weekly-recap-critical-cves-linux-ddos.html

8 Microsoft Learn, Block authentication flows with Conditional Access policy, Mar 2026. learn.microsoft.com/entra/identity/conditional-access/policy-block-authentication-flows

9 The Hacker News, Device code phishing hits 340+ Microsoft 365 orgs (Huntress, Unit 42, Sekoia), 25 Mar 2026. thehackernews.com/2026/03/device-code-phishing-hits-340-microsoft.html

10 Microsoft Learn, Authentication flows as a condition in Conditional Access, Mar 2026. learn.microsoft.com/entra/identity/conditional-access/concept-authentication-flows

11 Microsoft Learn, Microsoft-managed Conditional Access policies, accessed Nov 2026. learn.microsoft.com/entra/identity/conditional-access/managed-policies

12 Microsoft Learn, Restrict device code flow for Microsoft Teams devices, May 2026. learn.microsoft.com/entra/identity/conditional-access/policy-teams-devices-device-code-flow

13 Microsoft Learn, Token protection in Conditional Access, Aug 2026. learn.microsoft.com/entra/identity/conditional-access/concept-token-protection

14 Microsoft Learn, Revoke user access in an emergency in Microsoft Entra ID, Jun 2026. learn.microsoft.com/entra/identity/users/users-revoke-access

TRANSPUTEC

Close the door for good.

We help UK organisations lock down Microsoft 365 sign-in, from Conditional Access and passkeys to round-the-clock monitoring, so a typed code never becomes a breach.

Talk to our security team

transputec.com

NEXT IN THE SERIES

No. 12 · Cold chain, hot target



TRANSPUTEC

HOT TOPICS · PLAYBOOK
NO. 12 · NOVEMBER 2026



HOT TOPICS · BUILDING SYSTEMS AND OT

Cold chain, hot target.

Attackers warmed fridges and freezers in supermarkets across Europe by changing settings on internet-facing controllers. A practical playbook for finding, fencing and watching the building systems you rely on.

INSIDE

Contents

A practical guide to the building and operational systems most organisations forget they have connected: what happened to Europe's supermarket fridges, then what to find, fence and watch this week, this month and this quarter.

Foreword 03

Introduction 04

01 What happened 06

02 Find and fence 09

03 Watch and fall back 15

Questions and checklist 21

Sources 24

FOREWORD

The attack did not touch a single laptop. It changed a number on a fridge.

On the night of 11 October 2026, refrigeration controllers in hundreds of French supermarkets were switched into defrost mode. By morning, chilled and frozen food had been ruined and some equipment had overheated. Three weeks later a second wave hit stores in Belgium, Sweden, Ireland, Estonia and several other countries, and the UK's National Cyber Security Centre said it knew of a couple of cases here.

There was no ransom note and no stolen data. The damage was physical: food in skips, shelves emptied, staff working through the night. The systems involved were not part of the IT estate in most of these businesses. They were controllers installed and maintained by refrigeration contractors, often reachable from the internet so that engineers could check them remotely.

Fridges are only one example. Heating and ventilation, door access, CCTV, lifts, lighting and energy meters are run by the same kind of small, connected computer. In many organisations nobody can say how many there are, who looks after them or whether they can be reached from outside. This playbook is about answering those questions and acting on the answers.



The Transputec team
Transputec

INTRODUCTION

Three habits keep building systems out of the news.

The organisations hit in October and November were not careless with their IT. They had connected equipment that sat outside it, and that is where the gaps were.

Know what is connected

Keep a single list of every controller, panel and recorder that runs your buildings, with an owner, a supplier and a way it connects for each.

Fence it off

Take it off the public internet, replace default passwords, route supplier access through one controlled path and keep it apart from office IT.

Watch and fall back

Alert on setting changes, not just temperatures, and make sure staff can run the building by hand when a controller cannot be trusted.

If your freezer has a login page, someone else can find it.

In France, Europe's cyber agencies pointed to controller admin pages exposed to the internet and protected by weak or default passwords. That is a fixable problem, but only once you know where those pages are.

01

PART 01

What happened.

Two waves of tampering with refrigeration controllers in Europe, and a separate investigation at US military bases.

01 The October and November attacks

02 What is confirmed, and what is not

WHAT HAPPENED

From French fridges to UK abattoirs in three weeks

> **The damage was physical: food in skips, shelves emptied, staff working through the night.**

Overnight on 11 October 2026, attackers reached the refrigeration controllers of hundreds of French supermarkets and set them to defrost, so units heated their contents instead of cooling them.[1,2] Intermarché said some units reached 50°C, and reports described equipment catching fire. Les Mousquetaires, Coopérative U, Carrefour, Monoprix and E.Leclerc stores were among those affected.[2]

France's CERT-FR issued an alert on 12 October covering Danfoss AK-SM and AK-SC controllers, later adding Copeland and Dixell XWEB supervisors, and warned that attacks were probably still under way.[1] Danfoss said most units hit were older models it no longer updates, and ANSSI's head called for them to be taken off the internet or tightly filtered. The Paris prosecutor opened an inquiry.[2]

On 2 November a second wave struck. Delhaize, Carrefour, Spar and an IKEA store in Belgium, ICA and Coop in Sweden, 13 SuperValu stores in Ireland and a Selver store in Estonia were among those reporting tampered fridges and freezers, with further cases in the Netherlands, Portugal, Italy and Finland.[3,4] A contractor for Delhaize said evaporators had been switched to defrost. Belgium's federal prosecutor opened a criminal investigation.[4]

The UK was not spared. The NCSC said it was aware of a couple of instances where vulnerable technology had been exploited here, and the Association of Independent Meat Suppliers said some members' cold units had been affected, though they were empty at the time.[5] The NCSC's director of operations said the impact so far was minimal.

Separately, US officials are investigating freezer failures at around six military commissaries in August, including one at Fort Huachuca that entered defrost mode.[6] Two people familiar with the matter said officials suspect Iran-linked hackers, but the cause and attribution have not been confirmed.[7]

Nobody has claimed the European attacks, and agencies say a shared method does not prove a shared attacker.[4,8] Danfoss said the customers affected were mainly those who had not updated outdated software.[4] What the cases share is simpler: small, connected controllers, reachable from the internet, running old software or default passwords, and owned by nobody in IT.

CONFIRMED OR SUSPECTED

What we know, and what we do not

Early reporting on live incidents changes. This is the position on 4 November 2026.

QUESTION	CONFIRMED	NOT CONFIRMED
What changed	Remote setting changes that pushed units into defrost or high setpoints.[1,4]	Whether every reported case involved the same technique.
Which kit	Danfoss AK-SM and AK-SC controllers; Copeland and Dixell XWEB named by CERT-FR.[1]	The make of every affected unit outside France.
How they got in	ANSSI pointed to exposed admin interfaces and weak passwords in France.[8]	The entry route for the November wave and the US cases.
Known flaws	Danfoss fixed AK-SM 800A flaws, including a date-based password bypass, in 2025.[9]	That those flaws were used. ANSSI says they were not, in France.[8]
UK impact	A couple of UK cases known to the NCSC, impact so far minimal.[5]	How many UK sites are exposed today.
Who did it	Nobody has claimed responsibility.[3]	Any attribution, including the suspected Iran link in the US cases.[7]

02

PART 02

Find and fence.

You cannot protect a controller you do not know is there. Find it, take it off the internet and control who can reach it.

01 What counts as a building system

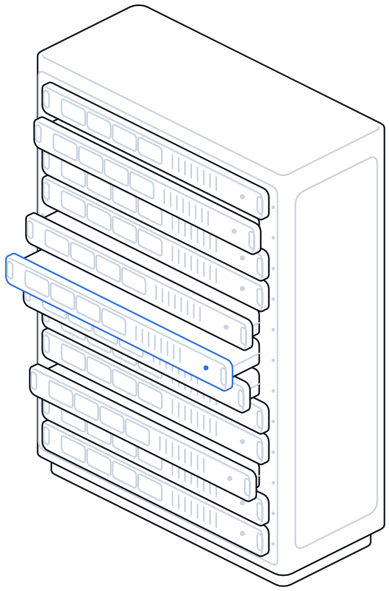
02 Building the inventory

03 Exposure, passwords and supplier access

IN SCOPE

Four families of connected building systems

Each is a small computer with a login, often invisible to IT. Researchers warned in August that such controllers could be hijacked.[10]



01 **Refrigeration and cold rooms**

Store supervisors, case controllers, cold-room panels and temperature loggers.

02 **Heating, ventilation and cooling**

Building management systems, air handlers, chillers and server room cooling.

03 **Access control and CCTV**

Door controllers, badge readers, video recorders and IP cameras.

04 **Power and services**

UPS units, generators, energy meters, lifts and lighting.

THIS WEEK

Build the building-systems inventory in five steps

A spreadsheet is enough. Sweden's cyber agency found quite a lot of exposed OT after the attacks; assume you have some too.[3]

01 Ask facilities and contractors first

Get every maintenance contract and ask each contractor to list the controllers they look after and how they connect to them.

02 Check what the internet can see

Register for NCSC Early Warning and scan your internet addresses, including separate broadband lines.

03 Walk the site

Look for routers, 4G modems and cables in plant rooms, freezer rooms and comms cupboards.

04 Record the essentials

Make, model, version, location, owner, supplier, how it connects, who holds the password, support status.

05 Agree an owner per device

One named person per system, usually in facilities, with IT and security named as advisers.

WHAT TO CHECK

Device by device: the questions that matter

Use these as the columns of your inventory. The red flags are what the attacks used.

CHECK	WHAT GOOD LOOKS LIKE	RED FLAG
Exposure	No admin page reachable from the internet, on any address.	A login page found by an external scan.
Passwords	Unique passwords, held by named people, changed from the factory setting.	Default logins, shared by every engineer for years.
Supplier access	One controlled route in, such as a VPN with MFA, logged and switched off when unused.	A contractor's always-on modem or open port.
Software	Supported model on the latest firmware, with vendor hardening applied.	End-of-life model or firmware years out of date.
Network	On a separate network segment, only talking to what it needs.	On the office network next to laptops and printers.
Records	Known-good configuration saved, including setpoints and defrost schedules.	Nobody knows what the settings should be.

01

Bring supplier remote access under control

Remote access is why most of these controllers were connected in the first place. Contractors need it to monitor alarms and fix faults. The aim is to keep the service and lose the open door.

WHY IT MATTERS

CERT-FR told operators to restore access only through a secure VPN or protected network, with contractor IP filtering as a stopgap at most.[1]

WHAT TO CHANGE

One managed route for all suppliers, with named accounts, MFA where possible and view-only access unless a change is needed.

BEFORE YOU CUT IT

CERT-FR advises checking insurance and service terms before stopping a contractor's data feed. Agree the new route with them first.[1]

WHAT TO MEASURE

Number of supplier routes into building systems, share with MFA, and how quickly a leaver's access is removed.

OWNER

Facilities manager, with the IT lead

Bring this to the monthly review, with a date for each action.

NCSC GUIDANCE

Eight principles for connecting operational technology

From the NCSC's Secure Connectivity Principles for OT, published with international partners in January 2026. They are goals, not minimum requirements.[11]

01 Balance the risks and opportunities

Connect a building system only when there is a clear business need, and record the risk you are accepting.

02 Limit the exposure of your connectivity

Nothing directly reachable from the internet. Prefer connections that start from inside and go out.

03 Centralise and standardise network connections

One route in for suppliers and remote staff, not a modem per contractor.

04 Use standardised and secure protocols

Encrypted, authenticated connections in place of old open protocols wherever the kit allows.

05 Harden your OT boundary and limit the impact of compromise

Firewalls between building systems and IT, and segments so one bad controller cannot reach the rest.

06 Log, monitor and plan to isolate

Log all connections, watch for the unusual and know how to cut a system off safely.

03

PART 03

Watch and fall back.

Assume a setting will one day be changed without permission. Make sure you notice quickly and can keep running.

01 When a controller is tampered with

02 Who owns building security

03 Your plan

RESPONSE

If a building controller has been tampered with

Based on CERT-FR and SentinelLABS advice. Physical safety and the stock come first, evidence a close second.

Make it safe

Move stock, switch to manual control or standby kit and check for overheating, fire or water risk.[8]

Preserve evidence

Photograph screens, export logs and configuration and note times before you reset anything.[8]

Cut the exposure

Remove internet access to the device and any similar devices on public addresses.[1]

Reset and reconfigure

Restart or factory reset, restore a known-good configuration, set new passwords and apply vendor hardening. A reset alone does not stop it happening again.[1]

Report and share

Report through the UK's official routes, tell the supplier and the manufacturer, and check your insurer's notification terms.

> **Ireland's Musgrave said its monitoring systems alerted it to the problem and it acted immediately. Fast detection limited the loss.[3]**

OWNERSHIP

Who owns building systems security?

The usual answer is nobody, or everybody. NCSC guidance on OT records also asks you to document third-party risks.[12]

Facilities owns the system

Facilities owns each controller, its contract and its fallback, because they run the building.

IT owns the network

IT provides the segment, the firewall rules, the single supplier route and the external scanning.

Security owns the watching

Security or your managed provider receives the logs and alerts and leads any incident.

Procurement owns the terms

Contracts set security duties for suppliers: named access, patching, notice of incidents and end-of-life dates.

> **Put building systems on the risk register with a named director as the senior owner.**

IN PRACTICE

Three organisations, three buildings

FOOD DISTRIBUTOR, TWO COLD STORES

Refrigeration on a contractor's modem

THE GAP

Cold-store controllers reachable on a public address so the contractor could check alarms remotely.

THE CHECK

External scan shows no login pages; a test change triggers an alert within minutes.

THE FIX

Exposure removed; contractor moved to a VPN with named logins; alerts added for setpoint and defrost changes.

WATCH OUT

Confirm the alarm feed to the contractor still works after the change.

PROFESSIONAL SERVICES FIRM, THREE OFFICES

Building management on the office network

THE GAP

Heating and access control panels on the same network as staff laptops, with factory passwords.

THE CHECK

A laptop on the office network can no longer reach the panels.

THE FIX

Panels moved to their own segment, passwords changed and recorded, supplier access through one route.

WATCH OUT

Landlord-managed systems may sit outside your control. Ask the landlord the same questions.

CARE HOME GROUP, 12 SITES

Medicine fridges and door entry

THE GAP

Medicine fridge loggers and door entry kit installed by different suppliers, with no single list.

THE CHECK

Every site can show its device list and its last manual temperature check.

THE FIX

Inventory built across all sites, an owner per home, and manual checks written into shift routines.

WATCH OUT

Fallback must work at night, when fewest staff are on site.

PRIORITIES

Fix first what is exposed and matters

Plot each building system by exposure and by what happens if a setting is changed. Act on the top right first.

↑ PHYSICAL IMPACT

MONITOR AND PLAN

High impact, internal only

Alert on setting changes, save a known-good configuration and rehearse manual running.

ACT THIS WEEK

High impact, internet-facing

Remove exposure, change passwords and restrict supplier access now. Refrigeration, heating and access control usually sit here.

MAINTAIN

Low impact, internal only

Keep on the inventory, keep supported and review once a year.

CLOSE THE DOOR

Low impact, internet-facing

Remove exposure. Even minor kit can become a route into the rest of the network.

INTERNET EXPOSURE →

YOUR PLAN

This week, this month, this quarter

Owners are suggestions. Adjust them to your structure.

WHEN	ACTIONS	OWNER
This week	List building systems with contractors. Register for Early Warning. Run an external scan. Take any exposed controller off the internet.	Facilities, with IT
This week	Change default and shared passwords on refrigeration, heating and access control. Check setpoints and defrost schedules.	Facilities manager
This month	Move supplier access to one controlled route. Put building systems on their own network segment. Save known-good configurations.	IT lead
This month	Set alerts for setting changes. Write and test manual fallback for cold storage, heating and doors.	Facilities and security
This quarter	Replace end-of-life controllers. Add security clauses to maintenance contracts. Rehearse a tampering scenario.	Head of facilities
This quarter	Report progress to the board with dated actions, owners and remaining risks.	Operations director

QUESTIONS TO ASK

For your board, and for your suppliers

Ask them out loud. Vague answers are the finding.

BOARD

- ? Do we know every building system that is connected, and who owns each one?
- ? Could anyone outside change a fridge, heating or door setting tonight?
- ? If they did, how fast would we know, and could we keep running by hand?

SUPPLIERS

- ? Which of our controllers can you reach remotely, how, and who on your team can log in?
- ? Are any of our devices end of life or behind on firmware, and what is your plan?
- ? Will you tell us within a set time if you suspect tampering on any customer's kit?

CHECKLIST

Is your cold chain locked down?

Tick what is true today. Anything blank is your next action.

- [ ] **A single list of connected building systems**
  With owner, supplier, model, version and connection for each.

- [ ] **Registered for NCSC Early Warning**
  And an external scan shows no building system login pages.

- [ ] **No default or shared passwords**
  Every account named, every factory password changed.

- [ ] **One controlled route for supplier access**
  With MFA where possible, logged and off when not in use.

- [ ] **Building systems separated from office IT**
  On their own segment, with firewall rules between.

- [ ] **Alerts on setting changes**
  Setpoints, defrost schedules and user accounts, not just temperature alarms.

- [ ] **Tested manual fallback**
  Staff know how to protect stock and run the building by hand.

- [ ] **Security terms in maintenance contracts**
  Including end-of-life dates and incident notification.

GLOSSARY

Words worth knowing

Operational technology (OT)

Computers that control physical equipment, such as fridges, boilers, doors and lifts, rather than handle data.

Building management system

Software and controllers that run heating, ventilation, cooling and other services across a building.

Controller

A small dedicated computer that runs a piece of equipment and usually has its own login page.

Setpoint

The target value a controller aims for, such as minus 18°C in a freezer.

Defrost cycle

A routine that warms a unit briefly to clear ice. Run for too long, it ruins the contents.

Internet exposure

When a device's login page or service can be reached directly from the public internet.

Default credentials

The username and password set by the maker, often published and widely known.

Segmentation

Splitting a network so that systems can only reach what they need.

End of life

When a manufacturer stops issuing security fixes for a product.

Early Warning

A free NCSC service that alerts UK organisations to exposed services and signs of compromise.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

1 CERT-FR (ANSSI), CERTFR-2026-ALE-012, security incident targeting remote controllers of refrigeration installations, 12 Oct 2026, updated 16 Oct 2026. cert.cyber.gouv.fr/alerte/CERTFR-2026-ALE-012

2 The Hacker News, attackers heat French supermarket refrigeration, Oct 2026. thehackernews.com/2026/10/attackers-heat-french-supermarket.html

3 NBC News with Reuters, supermarkets across Europe hit by new fridge cyberattacks, 2 Nov 2026. nbcnews.com/world/europe/european-supermarkets-hit-new-fridge-cyberattack-rcna606972

4 The Hacker News, new wave of refrigeration cyberattacks hits supermarkets across Europe, 3 Nov 2026. thehackernews.com/2026/11/second-wave-of-cyberattacks-hits.html

5 BBC News (syndicated), UK also affected by cyber-attack which hit European supermarket fridges, 3 Nov 2026. yahoo.com/news/world/articles/uk-affected-supermarket-fridge-hacks-094349012.html

6 Nextgov/FCW, Pentagon investigates suspected cyberattack behind military freezer failures, 29 Oct 2026. nextgov.com/cybersecurity/2026/10/pentagon-investigates-suspected-cyberattack-behind-military-freezer-failures/416926

7 Nextgov/FCW, officials suspect Iran in series of cyberattacks on military base freezers, 29 Oct 2026. nextgov.com/cybersecurity/2026/10/officials-suspect-iran-series-cyberattacks-military-base-freezers/416934

8 SentinelLABS, Defrost and Disrupt: an assessment of Europe's refrigeration attacks, 3 Nov 2026. sentinelone.com/labs/defrost-and-disrupt-an-assessment-of-europe-s-refrigeration-attacks

9 CISA, ICSA-25-140-03, Danfoss AK-SM 8xxA Series, 20 May 2025, updated 26 Aug 2025. cisa.gov/news-events/ics-advisories/icsa-25-140-03

10 TechCrunch, a fresh wave of cyberattacks has hit Europe's supermarket refrigerators, 2 Nov 2026. techcrunch.com/2026/11/02/a-fresh-wave-of-cyberattacks-has-hit-europes-supermarket-refrigerators-destroying-food-across-countries

11 NCSC with international partners, Secure connectivity principles for operational technology, Jan 2026. ncsc.gov.uk/collection/operational-technology/secure-connectivity

12 NCSC with international partners, Creating and maintaining a definitive view of your OT architecture. ncsc.gov.uk/collection/operational-technology/definitive-architecture-view

TRANSPUTEC

Want a second pair of eyes on your buildings?

Transputec helps UK organisations find connected building and operational systems, take them off the internet, bring supplier access under control and watch for changes around the clock.

Book a building systems review

transputec.com

NEXT IN THE SERIES

Back to No. 08 · When the cloud goes dark

